

[LOGO AREA]

AMMAR ALZAIEM

CYBERSECURITY | VAPT

SECURITY ASSESSMENT REPORT

Nikto and Burp Suite Assessment – Task 11

REPORT ID	AZ-WEB-2026-011
VERSION	1.0
ASSESSMENT DATE	11/9/2026
REPORT DATE	11/9/2026
PREPARED BY	Ammar Alzaiem
CLASSIFICATION	Public

Objective

The objective of this task was to assess the DVWA web application and its underlying web server for common security issues. Nikto was used for automated web-server scanning, while Burp Suite was used to inspect HTTP requests, responses, cookies, and application endpoints.

1. Nikto Scan

The DVWA server was scanned using Nikto:

The target was running on **port 80** with **Apache/2.2.8 (Ubuntu)** and **PHP/5.2.4-2ubuntu5.10**. Nikto completed 8,101 requests and reported 24 items.

The main findings were:

- Apache 2.2.8 and PHP 5.2.4 are outdated versions.
- X-Frame-Options and X-Content-Type-Options security headers are missing.
- The PHPSESSID and security cookies do not use the HttpOnly flag.
- The HTTP TRACE method is enabled.
- Directory indexing is enabled for /dvwa/config/ and /dvwa/docs/.
- /dvwa/CHANGELOG.txt is accessible.
- PHP version information is exposed through the X-Powered-By header.
- Apache MultiViews is enabled.

The outdated software and exposed directories are the most notable findings because they can provide additional information about the target and potentially increase the attack surface.

2. Burp Suite

Burp Suite was used to intercept and inspect DVWA's HTTP traffic.

The application uses the PHPSESSID cookie to maintain an authenticated session. During testing, changing the session cookie affected the current session, confirming that the cookie is important for maintaining authentication.

The main application endpoints identified during the assessment were:

Function	Endpoint
Login	/dvwa/login.php
Brute Force	/dvwa/vulnerabilities/brute/

Function	Endpoint
Command Execution	/dvwa/vulnerabilities/exec/
CSRF	/dvwa/vulnerabilities/csrf/

Burp was also useful for viewing the HTTP headers and cookies reported by Nikto and understanding how the application handles user sessions.

3. Findings Summary

Finding	Risk
Outdated Apache/PHP	High
Directory indexing	Medium
Missing security headers	Medium
Cookies without HttpOnly	Medium
HTTP TRACE enabled	Medium
Server/PHP information disclosure	Low
Exposed changelog	Low

4. Conclusion

The assessment identified several weaknesses in the DVWA environment, including outdated server software, missing security headers, insecure cookie configuration, directory indexing, and information disclosure.

Nikto was useful for quickly identifying server-side issues, while Burp Suite provided a better view of the application's HTTP traffic and session handling. The results also helped identify the main areas of the DVWA application that could be examined during further security testing.

